Implement and manage Zero Trust Network Access (ZTNA) using Zscaler

Group Details:

S. No.	Name	Register No.	Email Id
1	Kaviya Shree V	2322k0246	23bcs032@kprcas.ac.in
2	Saranya K	2322k0268	23bcs054@kprcas.ac.in
3	Anirudh K	2322k0220	23bcs006@kprcas.ac.in
4	Vasanth B	2322k0224	23bcs068@kprcas.ac.in

College Name: KPR College of Arts Science and Research

College Code: bruaz

PROJECT DETAILS

Title:

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler.

Introduction:

In modern organizations, employees, partners, and customers access company applications from different locations such as offices, homes, or public networks. Traditional security models relied on a perimeter-based approach, where once a user entered the corporate network through a VPN, they were trusted and given broad access.

However, this model is no longer secure due to increasing cyber threats and remote work environments.

To solve this problem, the Zero Trust security model was introduced. The main principle of Zero Trust is “Never Trust, Always Verify.” Every user, device, and application must be continuously authenticated and authorized before access is granted.

Zero Trust Network Access (ZTNA) is a security framework that implements this principle by allowing users to access only the specific applications they are authorized to use, instead of giving full network access.

Zscaler is a leading cloud-based cybersecurity platform that helps organizations implement ZTNA. It provides secure, identity-based access to applications without exposing the internal network to the internet.

Using Zscaler’s ZTNA solution (often through Zscaler Private Access – ZPA), organizations can:

- Provide secure remote access to internal applications
- Authenticate users and devices before granting access
- Limit access only to authorized applications
- Protect sensitive data and systems from cyber attacks
- Eliminate the need for traditional VPNs

ABSTRACT:

Traditional Virtual Private Network (VPN) architectures are increasingly inadequate for addressing modern cybersecurity threats. In conventional security models, once a user gains access through a VPN, they often receive broad network-level permissions. This can lead to security risks such as lateral movement, over-privileged access, and a larger attack surface for attackers. To overcome these limitations, organizations are shifting toward the Zero Trust security model, which follows the principle of "**Never Trust, Always Verify**."

This project focuses on the design, deployment, and management of a **Zero Trust Network Access (ZTNA)** solution **using Zscaler Private Access (ZPA)** within a large-scale institutional network. The primary objective is to replace traditional network-based access with application-specific and identity-driven connectivity, ensuring that users can access only the applications they are authorized to use.

The architecture involves deploying Zscaler App Connectors within the internal data center and integrating the system with existing Identity Providers such as Azure Active Directory and endpoint security tools to verify user identity and device posture. All user-to-application connections are securely established through a cloud-native broker, ensuring that internal applications remain invisible to the public internet and significantly reducing potential attack surfaces.

Additionally, the solution integrates with security monitoring platforms such as SIEM systems (for example, **QRadar**) for centralized logging and analysis, and threat intelligence platforms like **MISP** to support adaptive and policy-based access control. These integrations enable real-time monitoring, improved threat detection, and enhanced security management.

The implemented framework provides a scalable and secure access model that enforces the principle of least-privilege access while maintaining comprehensive audit visibility. Overall, the adoption of ZTNA using **Zscaler significantly strengthens the organization's security posture and improves resilience against evolving cyber threats.**

USE CASE SCENARIO:

Scenario 1:

Secure Remote Access for Faculty to ERP System

A faculty member working from home needs to access the university's ERP system to upload student grades. Using Zscaler Private Access (ZPA), they connect securely without being placed on the internal network. The system verifies their identity via Azure AD MFA and checks their device posture before granting access.

Output:

- User identity verified (Faculty_Group)
- Device posture compliant (Antivirus active, OS up-to-date)
- Secure micro-tunnel established to ERP Application only
- Internal network remains completely invisible to the user

Scenario 2:

Restricted Access for Student to Learning Management System

A student attempts to access the Learning Management System (LMS) from a personal laptop. The ZTNA policy verifies the student's identity through the university's identity provider and checks whether the device meets security requirements. Access is granted only to the LMS application.

Output:

- User identity verified (Student_Group)
- Device posture partially compliant (browser secure, but unmanaged device)
- Access granted only to LMS Application
- Access to other internal applications automatically blocked

Scenario 3:

Administrative Staff Access to Financial Application

An administrative staff member needs to access the financial management system from within the campus network. Even though the user is inside the network, ZTNA policies still verify identity and device posture before allowing access.

Output:

- User identity verified (Admin_Group)
- Device posture compliant (Corporate-managed device)

- Secure connection established only to Financial Application
- Unauthorized lateral movement prevented

Scenario 4:

Vendor Access to Maintenance System

An external IT vendor requires temporary access to the university's server maintenance portal to perform system updates. Zscaler ZTNA provides restricted, application-level access without allowing the vendor into the internal network.

Output:

- Vendor identity verified via secure authentication
- Time-based access policy applied (temporary access)
- Secure micro-tunnel created to Maintenance Portal only
- No visibility of other internal servers or applications

Scenario 5:

Blocked Access from Non-Compliant Device

A staff member tries to access the internal research database using a device that does not meet the organization’s security requirements (outdated OS and disabled antivirus). The ZTNA policy detects the non-compliance and blocks access.

Output:

- User identity verified (Research_Staff_Group)
- Device posture non-compliant (Outdated OS detected)
- Access to Research Database denied
- User redirected to remediation instructions to update device security

STAGE 1

Title:

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler.

Overview:

Modern organizations increasingly depend on cloud services, remote work environments, and internet-based applications to perform daily operations. While these technologies improve productivity and accessibility, they also introduce serious cybersecurity challenges. Traditional network security approaches rely heavily on Virtual Private Networks (VPNs), where users who successfully authenticate are granted broad access to the internal network. This model creates several security risks, including unauthorized access, lateral movement within the network, and exposure of sensitive internal systems to potential cyberattacks.

To address these limitations, organizations are adopting the Zero Trust security model, which operates on the principle of "Never Trust, Always Verify." In this approach, no user or device is trusted by default, even if they are inside the network. Every access request must be continuously verified based on user identity, device security status, and predefined security policies. Zero Trust Network Access (ZTNA) is a key implementation of this model, providing secure, identity-based access to applications without exposing the entire internal network.

This project focuses on implementing and managing Zero Trust Network Access (ZTNA) using Zscaler to provide secure user-to-application connectivity. The primary objective is to replace traditional network-level access with application-specific access control, ensuring that users can access only the applications they are authorized to use. This significantly reduces the attack surface and prevents unauthorized movement within the network.

The architecture of the proposed system uses Zscaler Private Access (ZPA), a cloud-based security service that securely connects users to internal applications. In this architecture, Zscaler App Connectors are deployed inside the organization's data center or private cloud environment. These connectors establish secure outbound connections to the Zscaler cloud platform, ensuring that internal applications remain hidden from the public internet and cannot be directly accessed by external users.

When a user attempts to access an application, the request is first routed through the Zscaler platform, where the user's identity is verified using an identity provider such as Azure Active Directory. The system may also use multi-factor authentication (MFA) to strengthen identity verification. Additionally, the system checks the device posture, ensuring that the device meets security requirements such as updated operating systems and active antivirus protection.

Once authentication and security checks are completed, a secure encrypted micro-tunnel is established between the user and the specific application they are authorized to access.

Importantly, the user is connected only to that application and not to the entire internal network, which prevents unauthorized access to other resources.

The project also supports security monitoring and logging, allowing administrators to track user activity, detect suspicious behavior, and enforce security policies. Integration with monitoring tools and security platforms helps organizations maintain visibility and respond quickly to potential threats.

Overall, the implementation of ZTNA using Zscaler provides a secure, scalable, and efficient access solution that protects organizational resources while enabling employees to access applications from any location securely. By adopting this modern security architecture, organizations can significantly reduce cyber risks and improve their overall network security posture.

Vulnerability Table:

S. No.	Vulnerability Name	CWE/CVE No.
1	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE - 22
2	Relative Path Traversal	CWE - 23
3	Absolute Path Traversal	CWE - 36
4	Improper Link Resolution Before File Access	CWE - 59
5	UNIX Symbolic Link (Symlink) Following	CWE - 61
6	Windows Hard Link	CWE - 65
7	Exposure of Sensitive Information to an Unauthorized Actor	CWE - 200
8	Exposure to Sensitive Information Through Sent Data	CWE - 201
9	Storage of File with Sensitive Data Under Web Root	CWE - 219
10	Incorrect Default Permissions	CWE - 276

REPORT:

1. VULNERABILITY NAME:

Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CWE/CVE No.:

CWE - 22

Owasp CATEGORY:

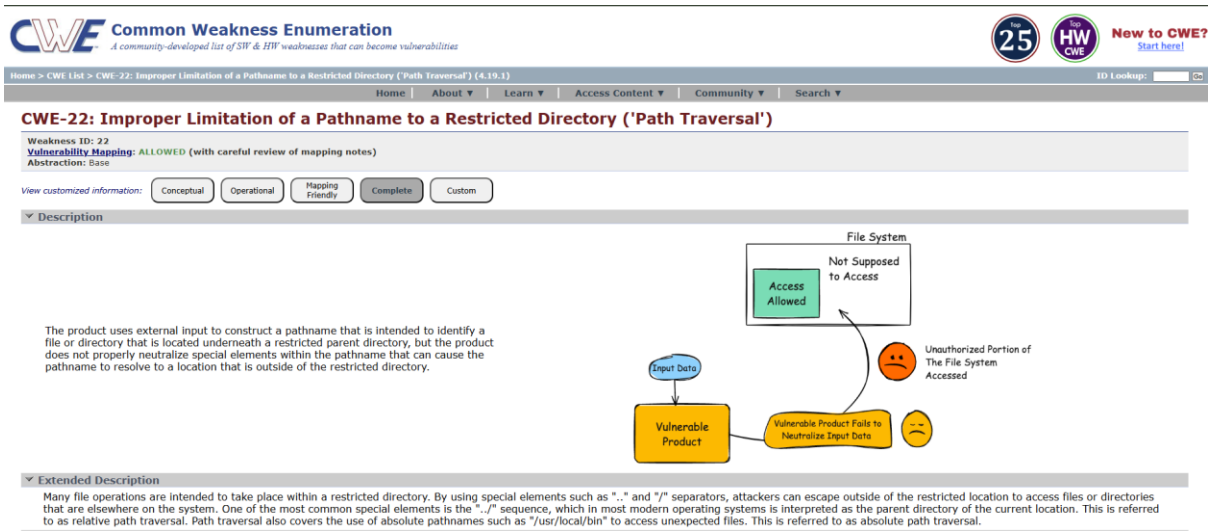
A01:2025 Broken Access Control

DESCRIPTION:

The product uses external input to construct a pathname that is intended to identify a file or directory that is located underneath a restricted parent directory, but the product does not properly neutralize special elements within the pathname that can cause the pathname to resolve to a location that is outside of the restricted directory.

BUSINESS IMPACT:

Path Traversal vulnerabilities can allow attackers to access sensitive files such as configuration files, system data, and user information without authorization. This can lead to data breaches, exposure of confidential information, and potential modification or deletion of critical files. As a result, organizations may face financial losses, legal and compliance issues, and damage to their reputation and customer trust.



2. VULNERABILITY NAME:

Relative Path Traversal

CWE/CVE No.:

CWE - 23

Owasp CATEGORY:

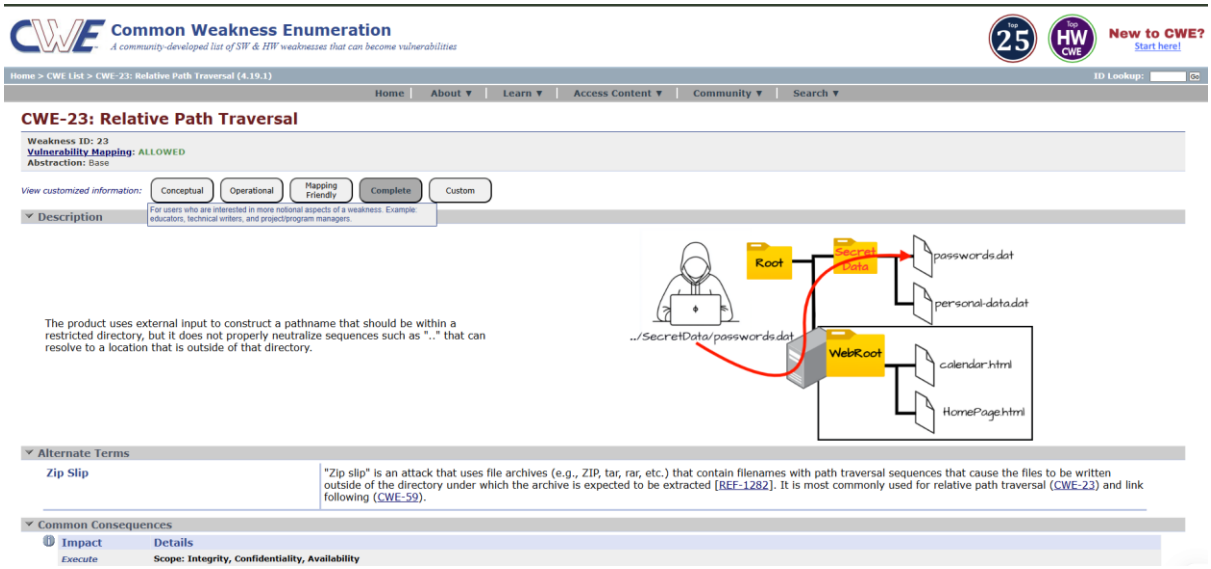
A01:2025 Broken Access Control

DESCRIPTION:

The product uses external input to construct a pathname that should be within a restricted but it does not properly neutralize sequences such as ".." that can resolve to a location that is outside of that directory.

BUSINESS IMPACT:

Relative Path Traversal vulnerabilities allow attackers to access files and directories outside the intended application folder by manipulating relative file paths. This can expose sensitive information such as configuration files, system credentials, and application source code. If exploited, it may lead to data breaches, unauthorized system access, and potential manipulation of critical files. Such incidents can result in financial losses, legal and compliance issues, service disruption, and damage to the organization's reputation and customer trust.



3. VULNERABILITY NAME:

Absolute Path Traversal

CWE/CVE No.:

CWE - 36

Owasp CATEGORY:

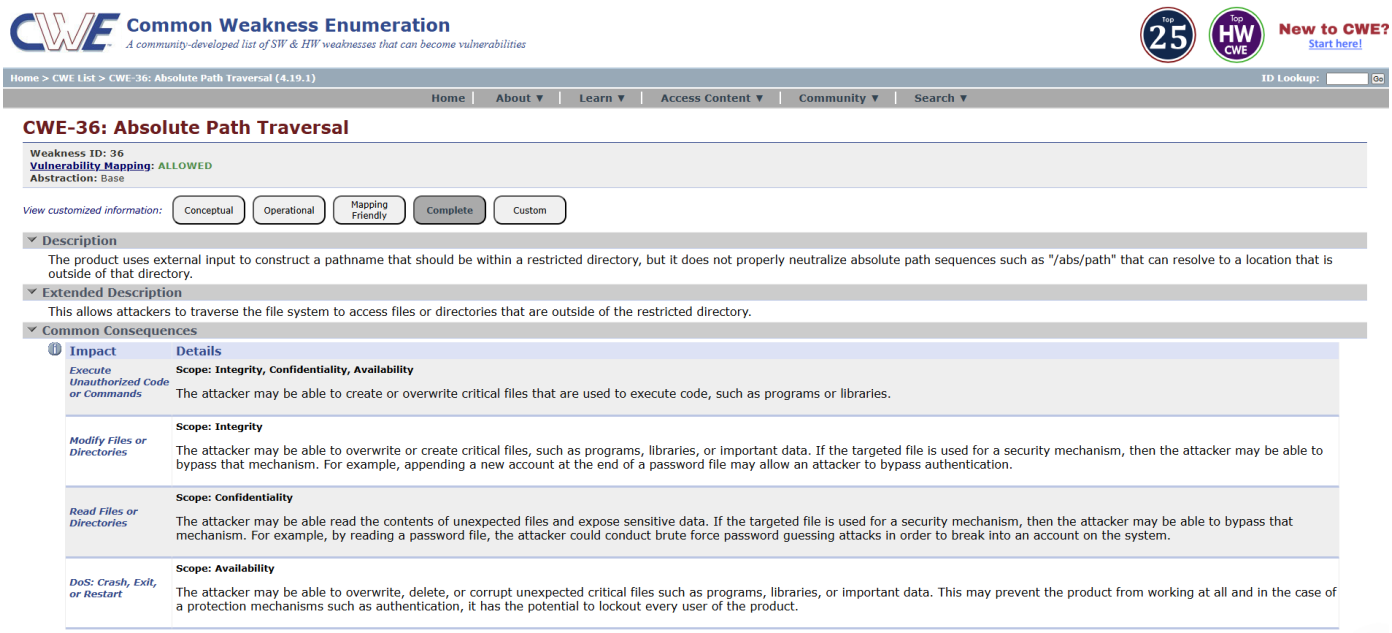
A01:2025 Broken Access Control

DESCRIPTION:

The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

BUSINESS IMPACT:

Absolute Path Traversal allows attackers to directly specify absolute file paths to access restricted system files. This may expose sensitive information such as system configurations, application source code, and credentials. If exploited, attackers could gather critical system details that enable further attacks, leading to data breaches, operational disruption, and reputational damage for the organization.



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-36: Absolute Path Traversal (4.19.1)

ID Lookup:

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-36: Absolute Path Traversal

Weakness ID: 36
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

Extended Description

This allows attackers to traverse the file system to access files or directories that are outside of the restricted directory.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	**Scope: Integrity, Confidentiality, Availability** The attacker may be able to create or overwrite critical files that are used to execute code, such as programs or libraries.
Modify Files or Directories	**Scope: Integrity** The attacker may be able to overwrite or create critical files, such as programs, libraries, or important data. If the targeted file is used for a security mechanism, then the attacker may be able to bypass that mechanism. For example, appending a new account at the end of a password file may allow an attacker to bypass authentication.
Read Files or Directories	**Scope: Confidentiality** The attacker may be able read the contents of unexpected files and expose sensitive data. If the targeted file is used for a security mechanism, then the attacker may be able to bypass that mechanism. For example, by reading a password file, the attacker could conduct brute force password guessing attacks in order to break into an account on the system.
DoS: Crash, Exit, or Restart	**Scope: Availability** The attacker may be able to overwrite, delete, or corrupt unexpected critical files such as programs, libraries, or important data. This may prevent the product from working at all and in the case of a protection mechanisms such as authentication, it has the potential to lockout every user of the product.

4. VULNERABILITY NAME:

Improper Link Resolution Before File Access (Link Following)

CWE/CVE No.:

CWE - 59

Owasp CATEGORY:

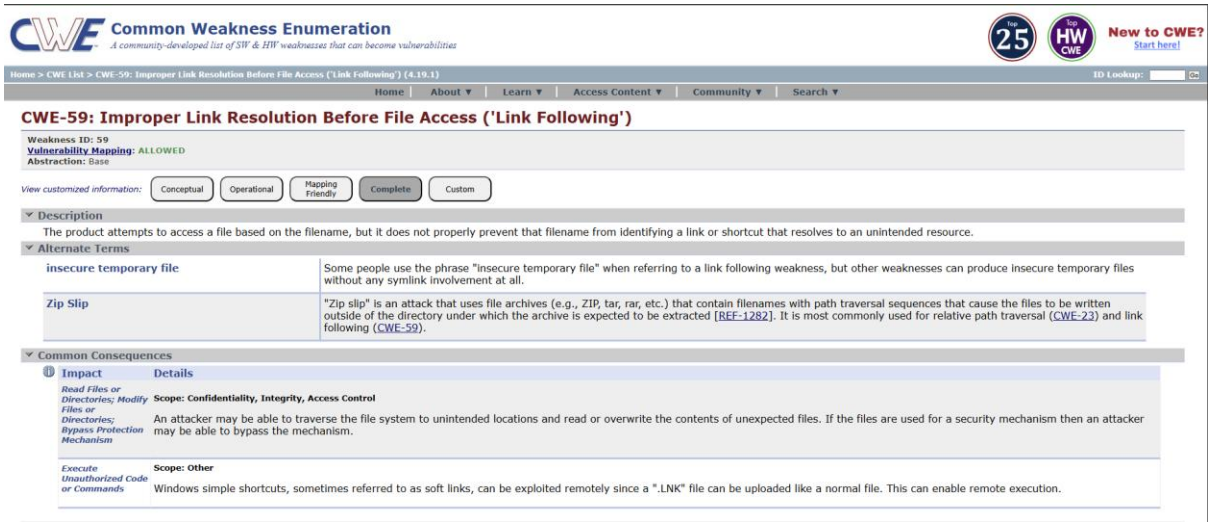
A01:2025 Broken Access Control

DESCRIPTION:

The product attempts to access a file based on the filename, but it does not properly prevent that filename from identifying a link or shortcut that resolves to an unintended resource.

BUSINESS IMPACT:

This vulnerability occurs when applications follow file links without properly validating them. Attackers may exploit this to access unauthorized files or manipulate file operations. As a result, sensitive data may be exposed or critical system files may be modified, causing security breaches, compliance violations, and potential financial loss.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-59: Improper Link Resolution Before File Access ('Link Following') (4.19.1)

ID Lookup:

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-59: Improper Link Resolution Before File Access ('Link Following')

Weakness ID: 59
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product attempts to access a file based on the filename, but it does not properly prevent that filename from identifying a link or shortcut that resolves to an unintended resource.

Alternate Terms

insecure temporary file	Some people use the phrase "insecure temporary file" when referring to a link following weakness, but other weaknesses can produce insecure temporary files without any symlink involvement at all.
Zip Slip	"Zip slip" is an attack that uses file archives (e.g., ZIP, tar, rar, etc.) that contain filenames with path traversal sequences that cause the files to be written outside of the directory under which the archive is expected to be extracted [REF-1282]. It is most commonly used for relative path traversal (CWE-23) and link following (CWE-59).

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories; Bypass Protection Mechanism	**Scope: Confidentiality, Integrity, Access Control** An attacker may be able to traverse the file system to unintended locations and read or overwrite the contents of unexpected files. If the files are used for a security mechanism then an attacker may be able to bypass the mechanism.
Execute Unauthorized Code or Commands	**Scope: Other** Windows simple shortcuts, sometimes referred to as soft links, can be exploited remotely since a ".LNK" file can be uploaded like a normal file. This can enable remote execution.

5. VULNERABILITY NAME:

UNIX Symbolic Link (Symlink) Following

CWE/CVE No.:

CWE - 61

Owasp CATEGORY:

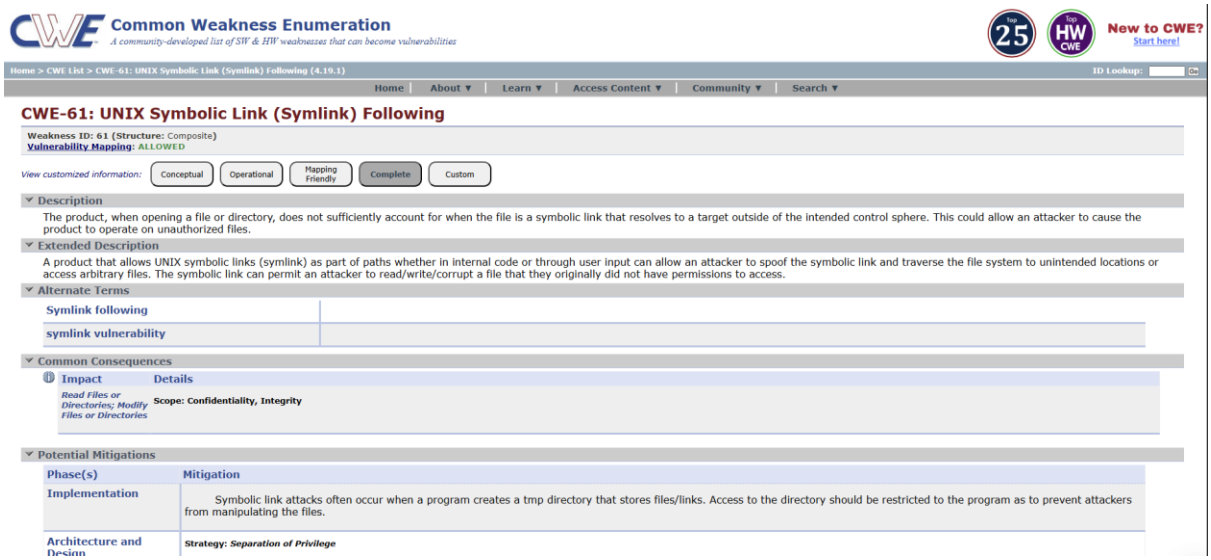
A01:2025 Broken Access Control

DESCRIPTION:

The product, when opening a file or directory, does not sufficiently account for when the file is a symbolic link that resolves to a target outside of the intended control sphere. This could allow an attacker to cause the product to operate on unauthorized files.

BUSINESS IMPACT:

If a system improperly handles symbolic links, attackers can create malicious symlinks to redirect file operations to sensitive files. This can allow unauthorized access, modification, or deletion of important data. Such exploitation can compromise system integrity, disrupt operations, and expose confidential information.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-61: UNIX Symbolic Link (Symlink) Following (4.19.1)

ID Lookup:

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-61: UNIX Symbolic Link (Symlink) Following

Weakness ID: 61 (Structure: Composite)
Vulnerability Mapping: ALLOWED

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product, when opening a file or directory, does not sufficiently account for when the file is a symbolic link that resolves to a target outside of the intended control sphere. This could allow an attacker to cause the product to operate on unauthorized files.

Extended Description

A product that allows UNIX symbolic links (symlink) as part of paths whether in internal code or through user input can allow an attacker to spoof the symbolic link and traverse the file system to unintended locations or access arbitrary files. The symbolic link can permit an attacker to read/write/corrupt a file that they originally did not have permissions to access.

Alternate Terms

Symlink following
symlink vulnerability

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories	Scope: Confidentiality, Integrity

Potential Mitigations

Phase(s)	Mitigation
Implementation	Symbolic link attacks often occur when a program creates a tmp directory that stores files/links. Access to the directory should be restricted to the program as to prevent attackers from manipulating the files.
Architecture and Design	Strategy: Separation of Privilege

6. VULNERABILITY NAME:

Windows Hard Link

CWE/CVE No.:

CWE – 65

Owasp CATEGORY:

A01:2025 Broken Access Control

DESCRIPTION:

The product, when opening a file or directory, does not sufficiently handle when the name is associated with a hard link to a target that is outside of the intended control sphere. This could allow an attacker to cause the product to operate on unauthorized files.

BUSINESS IMPACT:

Windows Hard Link vulnerabilities may allow attackers to manipulate file access by linking protected files to accessible locations. This can lead to unauthorized file modification or privilege escalation. The organization may experience data corruption, security breaches, and potential loss of critical system functionality.

Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-65: Windows Hard Link (4.19.1)

ID Lookup:

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-65: Windows Hard Link

Weakness ID: 65
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product, when opening a file or directory, does not sufficiently handle when the name is associated with a hard link to a target that is outside of the intended control sphere. This could allow an attacker to cause the product to operate on unauthorized files.

Extended Description

Failure for a system to check for hard links can result in vulnerability to different types of attacks. For example, an attacker can escalate their privileges if a file used by a privileged program is replaced with a hard link to a sensitive file (e.g. AUTOEXEC.BAT). When the process opens the file, the attacker can assume the privileges of that process, or prevent the program from accurately processing data.

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories	**Scope: Confidentiality, Integrity**

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design	**Strategy:** ***Separation of Privilege*** Follow the principle of least privilege when assigning access rights to entities in a software system. Denying access to a file can prevent an attacker from replacing that file with a link to a sensitive file. Ensure good compartmentalization in the system to provide protected areas that can be trusted.

7. VULNERABILITY NAME:

Exposure of Sensitive Information to an Unauthorized Actor

CWE/CVE No.:

CWE - 200

Owasp CATEGORY:

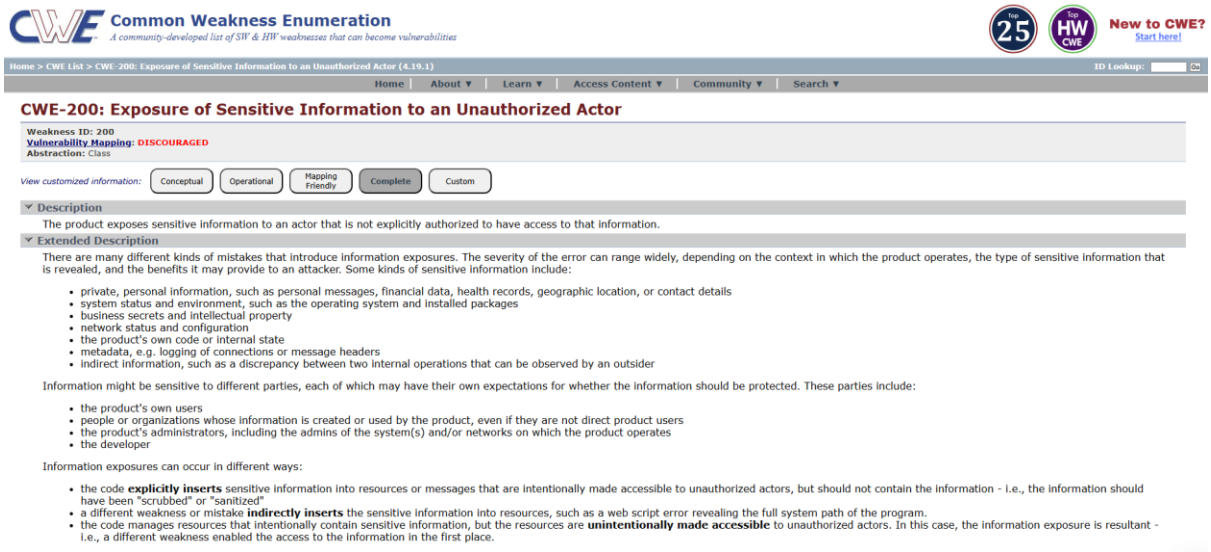
A01:2025 Broken Access Control

DESCRIPTION:

The product exposes sensitive information to an actor that is not explicitly authorized to have access to that information.

BUSINESS IMPACT:

Sensitive information such as personal data, credentials, or internal system details may be exposed to unauthorized users. This can result in data breaches, identity theft, regulatory penalties, and serious damage to the organization's reputation and customer trust.



Common Weakness Enumeration

A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-200: Exposure of Sensitive Information to an Unauthorized Actor (4.19.1)

ID Lookup:

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Weakness ID: 200
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product exposes sensitive information to an actor that is not explicitly authorized to have access to that information.

Extended Description

There are many different kinds of mistakes that introduce information exposures. The severity of the error can range widely, depending on the context in which the product operates, the type of sensitive information that is revealed, and the benefits it may provide to an attacker. Some kinds of sensitive information include:

- private, personal information, such as personal messages, financial data, health records, geographic location, or contact details
- system status and environment, such as the operating system and installed packages
- business secrets and intellectual property
- network status and configuration
- the product's own code or internal state
- metadata, e.g. logging of connections or message headers
- indirect information, such as a discrepancy between two internal operations that can be observed by an outsider

Information might be sensitive to different parties, each of which may have their own expectations for whether the information should be protected. These parties include:

- the product's own users
- people or organizations whose information is created or used by the product, even if they are not direct product users
- the product's administrators, including the admins of the system(s) and/or networks on which the product operates
- the developer

Information exposures can occur in different ways:

- the code **explicitly inserts** sensitive information into resources or messages that are intentionally made accessible to unauthorized actors, but should not contain the information - i.e., the information should have been "scrubbed" or "sanitized"
- a different weakness or mistake **indirectly inserts** the sensitive information into resources, such as a web script error revealing the full system path of the program.
- the code manages resources that intentionally contain sensitive information, but the resources are **unintentionally made accessible** to unauthorized actors. In this case, the information exposure is resultant - i.e., a different weakness enabled the access to the information in the first place.

8. VULNERABILITY NAME:

Exposure of Sensitive Information Through Sent Data

CWE/CVE No.:

CWE - 201

Owasp CATEGORY:

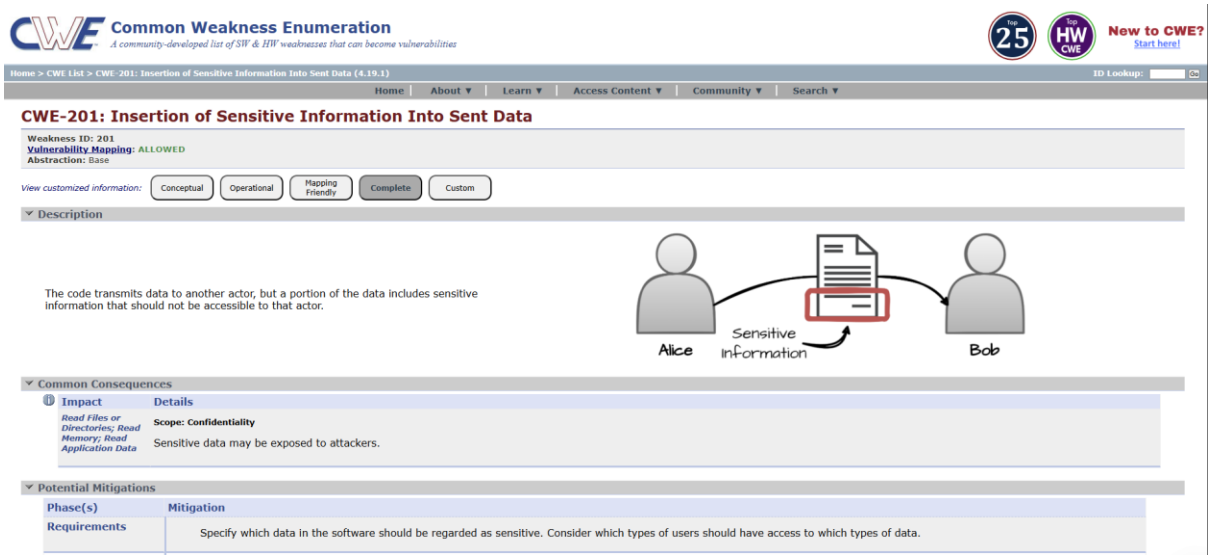
A01:2025 Broken Access Control

DESCRIPTION:

The code transmits data to another actor, but a portion of the data includes sensitive information that should not be accessible to that actor.

BUSINESS IMPACT:

This vulnerability may expose sensitive information while data is being transmitted between systems or users. Attackers may intercept or access confidential information such as authentication tokens, personal data, or financial records. Such exposure can lead to privacy violations, financial loss, and legal consequences.



9. VULNERABILITY NAME:

Storage of File with Sensitive Data Under Web Root4

CWE/CVE No.:

CWE - 219

Owasp CATEGORY:

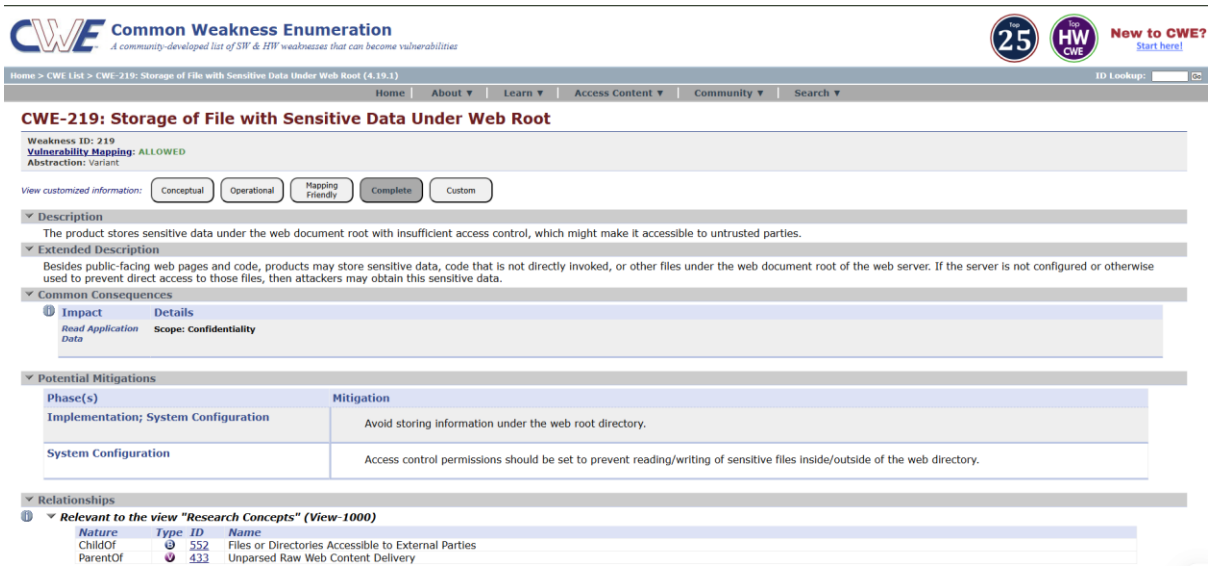
A01:2025 Broken Access Control

DESCRIPTION:

The product stores sensitive data under the web document root with insufficient access control, which might make it accessible to untrusted parties.

BUSINESS IMPACT:

Storing sensitive files within the web root makes them directly accessible through a browser. Attackers may download confidential files such as backups, configuration files, or user data. This can lead to significant data exposure, compliance violations, and loss of organizational credibility.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-219: Storage of File with Sensitive Data Under Web Root (4.19.1)

ID Lookup:

Home | About ▾ | Learn ▾ | Access Content ▾ | Community ▾ | Search ▾

CWE-219: Storage of File with Sensitive Data Under Web Root

Weakness ID: 219
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product stores sensitive data under the web document root with insufficient access control, which might make it accessible to untrusted parties.

Extended Description

Besides public-facing web pages and code, products may store sensitive data, code that is not directly invoked, or other files under the web document root of the web server. If the server is not configured or otherwise used to prevent direct access to those files, then attackers may obtain this sensitive data.

Common Consequences

Impact	Details
Read Application Data	Scope: Confidentiality

Potential Mitigations

Phase(s)	Mitigation
Implementation; System Configuration	Avoid storing information under the web root directory.
System Configuration	Access control permissions should be set to prevent reading/writing of sensitive files inside/outside of the web directory.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	B	552	Files or Directories Accessible to External Parties
ParentOf	V	433	Unparsed Raw Web Content Delivery

10.VULNERABILITY NAME:

Incorrect Default Permissions

CWE/CVE No.:

CWE - 276

Owasp CATEGORY:

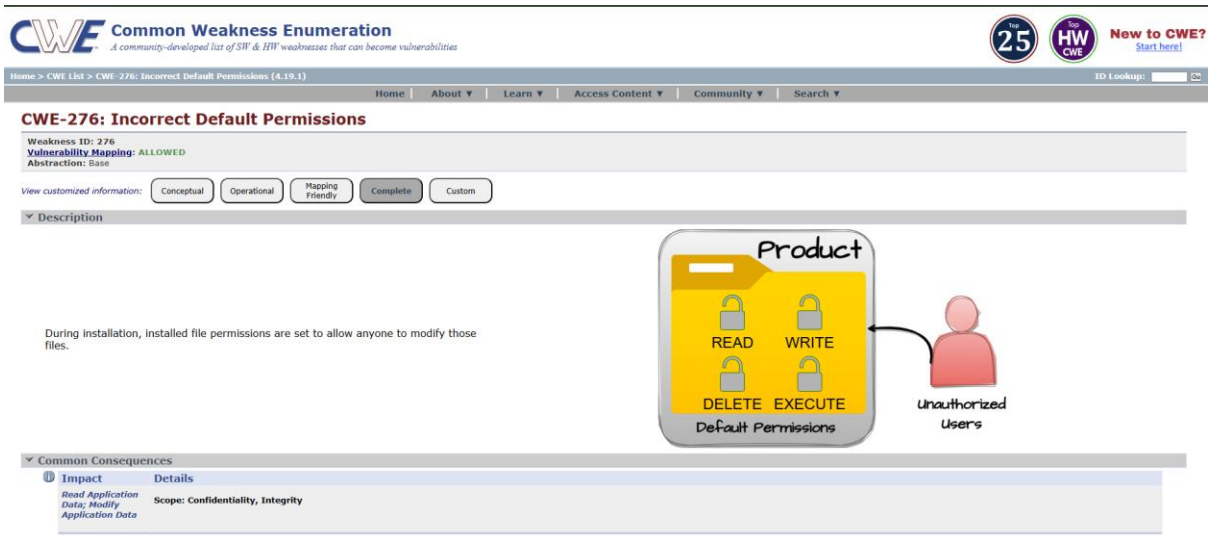
A01:2025 Broken Access Control

DESCRIPTION:

During installation, installed file permissions are set to allow anyone to modify those files.

BUSINESS IMPACT:

Incorrect default permissions may grant excessive access to files or system resources. Unauthorized users could read, modify, or delete critical data. This increases the risk of data leakage, system compromise, and operational disruptions, potentially causing financial and reputational damage to the organization.



STAGE 2:

TITLE: Nessus Scan

OVERVIEW:

A **Nessus Scan** is a vulnerability assessment process used to identify security weaknesses, misconfigurations, and potential threats in computer systems, networks, and applications. It is performed using **Nessus vulnerability scanner**, a widely used security tool developed by **Tenable**. Nessus helps organizations detect vulnerabilities before attackers can exploit them, allowing security teams to improve their overall cybersecurity posture.

Nessus works by scanning systems, servers, network devices, and applications to detect known vulnerabilities based on a large and continuously updated vulnerability database. The tool compares the system configuration and software versions with known security flaws listed in vulnerability standards such as **Common Vulnerabilities and Exposures (CVE)** and **Common Weakness Enumeration (CWE)**. If a vulnerability is detected, Nessus reports it along with its severity level and recommended remediation steps.

The scanning process usually begins by defining a target such as an IP address, domain, or network range. Nessus then performs various security checks including port scanning, service detection, vulnerability identification, and configuration analysis. The tool can detect issues such as outdated software, weak passwords, missing security patches, insecure network services, and improper system configurations.

One of the key features of Nessus is its ability to categorize vulnerabilities based on their severity levels, such as **Critical, High, Medium, Low, and Informational**. This classification helps security teams prioritize which vulnerabilities need immediate attention. After the scan is completed, Nessus generates detailed reports that include the vulnerability name, description, risk level, affected systems, and recommended mitigation steps.

Nessus scans are commonly used in **security audits, compliance assessments, penetration testing preparation, and regular vulnerability management programs**. Organizations perform these scans regularly to ensure that their systems remain secure and compliant with security standards and best practices.

Overall, a Nessus scan plays an important role in proactive cybersecurity by helping organizations detect and address vulnerabilities early. By identifying security weaknesses before they can be exploited, Nessus helps reduce the risk of cyberattacks, protect sensitive data, and maintain the reliability and security of IT infrastructure.

List of Vulnerability: -

S. No	Vulnerability Name	Severity	Plugin
1	HSTS Missing From HTTPS Server (RFC 6797)	Medium	142960
2	SSL Certificate Information Disclosure	Info	10863
3	SSL/TLS Recommended Cipher Suites	Info	56984
4	TLS NPN Supported Protocol Enumeration	Info	87242
5	Web Server Crafted Request Vendor/Version Information Disclosure	Info	11239
6	Service Detection	Info	22964
7	Nessus SYN Scanner	Info	11219
8	Nessus Scan Information	Info	19506
9	TLS Version 1.2 Protocol Detection	Info	136318
10	HyperText Transfer Protocol (HTTP) Information	Info	24260

REPORT: -

1) **Vulnerability Name: - 142960 - HSTS Missing From HTTPS Server (RFC 6797)**

Severity: - MEDIUM

Plugin: - 142960

Port: - 443/TCP

Description: - The remote web server is not enforcing HSTS, as defined by RFC 6797. HSTS is an optional response header that can be configured on the server to instruct the

browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS.

Business Impact: - The absence of HSTS makes the website vulnerable to downgrade and man-in-the-middle attacks, allowing attackers to intercept or manipulate user communications. Sensitive information such as login credentials and session cookies may be exposed during insecure HTTP connections. This can lead to unauthorized account access and data breaches. As a result, the organization may face loss of user trust, reputational damage, and potential compliance issues.

2) **Vulnerability Name: -10863-SSL Certificate Information Disclosure**

Severity: - INFO

Plugin: - 10863

Port: - 443/TCP

Description: - The plugin connects to the SSL service and retrieves the X.509 certificate information used by the server. It displays details such as issuer, validity period, encryption algorithm, and key length. This is mainly used for informational and verification purposes.

Solution: - Ensure that the SSL certificate is valid, uses strong encryption, and is renewed before expiration. Regular certificate monitoring is recommended.

Business Impact: - This finding is informational but may reveal certificate and server configuration details. Attackers could use this information during reconnaissance. Proper certificate management helps maintain secure communication.

3) **Vulnerability Name: - 56984 - SSL/TLS Recommended Cipher Suites-**

Severity: - INFO

Plugin: - 56984

Port: - 443

Description: - The remote host has open SSL/TLS ports which advertise discouraged cipher suites. It is recommended to only enable support for the following cipher suites

Solution: - Only enable support for recommened cipher suites.

Business Impact: - If weak cipher suites are enabled, attackers may exploit them to weaken encrypted communications. This can lead to potential data interception or cryptographic attacks. Using strong cipher suites ensures secure data transmission and improves system security.

4) **Vulnerability Name: - 87242 - TLS NPN Supported Protocol Enumeration**

Severity: - INFO

Plugin: - 87242

Port: - 443/TCP

Description: - The plugin checks whether the server supports TLS Next Protocol Negotiation (NPN). It enumerates the protocols that the server can negotiate during the TLS handshake. This information helps identify the protocols supported by the server for secure communication.

Solution: - Review the supported protocols and ensure only secure and required protocols are enabled. Disable outdated or unnecessary protocols to reduce the attack surface. Regularly update TLS configurations to follow security best practices.

Business Impact: - Although informational, exposed protocol details may assist attackers during reconnaissance. Knowledge of supported protocols can help attackers identify potential weaknesses. Proper configuration reduces the risk of protocol-based attacks.

5) Vulnerability Name: - 11239 - Web Server Crafted Request Vendor/Version Information Disclosure

Severity: - INFO

Plugin: - 11239

Port: - 443/TCP

Description: - The web server running on the remote host appears to be hiding its version or name, which is a good thing. However, using a specially crafted request, Nessus was able to discover the information.

Solution: - No generic solution is known. Contact your vendor for a fix or a workaround.

Business Impact: - Disclosure of server vendor and version information may assist attackers in identifying known vulnerabilities. Attackers can use this information to plan targeted attacks against the system. Hiding server details helps reduce the risk of reconnaissance-based attacks.

6) Vulnerability Name: - 22964 - Service Detection

Severity: - INFO

Plugin: - 22964

Port: - 80

Description: - Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Solution: - **N/A**

Business Impact: - Service information disclosure may help attackers understand the system environment. This information can be used during reconnaissance to identify potential attack points. Limiting exposed services reduces the overall attack surface.

7) Vulnerability Name: - 11219 - Nessus SYN scanner

Severity: - INFO

Plugin: - 11219

Port: - 80 (or) 443

Description: - This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target. Note that SYN scans are less intrusive than TCP (full

connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution: - Protect your target with an IP filter.

Business Impact: - Open ports can expose network services to potential attackers. Attackers may use this information to identify entry points for further attacks. Proper port management helps reduce the risk of unauthorized access.

8) Vulnerability Name: - 19506 – Nessus Scan Information

Severity: - INFO

Plugin: - 19506

Port: - N/A

Description: - This plugin provides information about the Nessus scan performed on the target host. It includes details such as the scanner type, Nessus engine version, plugin set version, and the port scanning method used. It also shows scan date, duration, port range scanned, and parallel host/check configuration.

Solution: - No remediation is required since this is an informational plugin. Ensure that scan reports are stored securely and accessible only to authorized personnel.

Business Impact: - This finding does not indicate a vulnerability but provides details about the scanning process. However, exposed scan information could reveal security assessment activities if accessed by unauthorized users. Proper access control for scan reports is recommended.

9) Vulnerability Name: - 136318 - TLS Version 1.2 Protocol Detection

Severity: - INFO

Plugin: - 136318

Port: - 443

Description: - This plugin detects whether the remote service supports TLS version 1.2 for secure communication. TLS 1.2 is a widely used protocol that provides strong encryption and secure data transmission between clients and servers. The result confirms the availability of this protocol on the target system.

Solution: - Ensure that TLS 1.2 or higher versions such as TLS 1.3 are enabled for secure communication. Disable older and insecure protocols like SSL and TLS 1.0/1.1 to improve security.

Business Impact: - Supporting TLS 1.2 improves the security of encrypted communications. However, if older protocols are also enabled, attackers may attempt downgrade attacks. Proper TLS configuration ensures strong data protection.

10) Vulnerability Name: - 24260 - HyperText Transfer Protocol (HTTP) Information

Severity: - INFO

Plugin: - 24260

Port: - 80 (or) 443

Description: - This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive is enabled, etc…This test is informational only and does not denote any security problem.

Solution: - Configure the web server to limit unnecessary HTTP methods and hide server information in HTTP headers. Implement proper security configurations to reduce information disclosure.

Business Impact: - Disclosure of HTTP service information may assist attackers in identifying server configurations. Attackers can use this data during reconnaissance to plan further attacks. Restricting unnecessary information improves overall security.

STAGE 3:

TITLE: Implement and manage Zero Trust Network Access (ZTNA) using Zscaler.

OVERVIEW:

• Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is a cybersecurity model that enables secure remote connectivity to an organization's internal applications and resources based on well-defined access control policies. Unlike traditional Virtual Private Networks (VPNs), which typically allow users to access a large portion of the internal network once connected, ZTNA follows the principle of "never trust, always verify." Access is granted only to the particular applications required by the user, and only after confirming both the user's identity and the security status of their device.

ZTNA plays an important role in modern security architecture. It shifts organizations away from the traditional concept of a trusted internal network and an untrusted external environment, often called the "castle-and-moat" model. Instead, ZTNA hides internal networks from direct internet exposure and creates secure, one-to-one encrypted connections between users and specific applications. This approach significantly minimizes the attack surface and prevents threats such as attackers moving laterally within the network.

• The ZTNA Access Cycle

The ZTNA access cycle represents an ongoing process that verifies identity, establishes secure communication, and enforces security policies whenever access is requested. The main stages are:

1. **User Request:**
   A user from any location - such as the office, home, or a public network - requests access to an internal application like an HR portal, financial system, or internal development repository.

2. **Identity and Device Verification:**
   Before allowing access, the ZTNA system authenticates the user through mechanisms like multi-factor authentication (MFA) and checks the device's security condition. This may involve confirming that antivirus software is updated, the firewall is active, and the system is free from compromise.

3. **Policy Enforcement:**
   The system reviews the predefined access policies to determine whether the user, device, and context meet the required conditions for accessing the requested application.

4. **Establish Secure Connection:**
   If the request satisfies the policy requirements, the ZTNA system sets up a secure encrypted micro-tunnel between the user's device and the specific application. Importantly, the user does not gain access to the internal network itself, only to the designated application.

5. **Continuous Monitoring:**
   During the session, the ZTNA system continuously observes the connection for unusual activity. If suspicious behavior is detected or the device's security posture changes, the connection can be terminated immediately.

6. **Logging and Analytics:**
   Every access attempt—successful or unsuccessful—is recorded and analyzed. These logs assist in auditing, identifying threats, and improving future access policies.

• Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-based security platform that provides security services directly from the cloud rather than relying on traditional on-premises hardware like VPN appliances. For Zero Trust access, Zscaler offers Zscaler Private Access (ZPA), a service that enables secure, identity-driven access to private applications without placing users on the internal network.

Zscaler ZPA works on a simple concept: the application is effectively hosted within the Zscaler cloud environment, and users connect to it through that cloud layer. The system collects information from several sources, including:

1. **Identity Providers (IdP):**
   Platforms such as Azure AD, Okta, or Ping Identity verify user identities**.**

2. **Device Posture Partners:**
   Security tools like CrowdStrike, Tanium, or Microsoft Defender for Endpoint assess the health and compliance of user devices.

3. **Business Applications:**
   Internal applications such as web portals, file servers, or legacy systems hosted in data centers or public cloud environments like AWS or Azure.

4. **Zscaler App Connectors:**
   Lightweight software components installed in data centers or cloud environments that initiate outbound connections to the Zscaler cloud, ensuring that internal servers remain hidden from the public internet.

Based on the collected information, Zscaler enforces several security policies:

1. **Identity-Based Access:**
   Access rules are based on user identities and groups rather than IP addresses.

2. **Application Segmentation:**
   Users are allowed to access only specific applications instead of entire network segments.

3. **Least Privilege Access:**
   Users receive only the minimum permissions necessary to perform their tasks.

• The Zscaler ZTNA Cycle

The Zscaler ZTNA cycle demonstrates how ZTNA principles are implemented using the Zscaler cloud platform. The process generally includes the following steps:

1. **User Login and Authentication:**
   When a user attempts to access an internal application, they are redirected to their organization's Identity Provider for authentication and MFA verification.

2. **Device Posture Check (Integration):**
   Zscaler interacts with integrated endpoint security solutions to verify that the user's device meets the organization's security requirements.

3. **Policy Lookup and Decision:**
   The Zscaler cloud evaluates the access request by checking user identity, device condition, and contextual information such as time and location against defined policies.

4. **Establishing the Micro-tunnel:**
   After authorization, Zscaler instructs the Client Connector on the user's device and the App Connector within the data center to create a secure encrypted tunnel, enabling access to the specific application.

5. **Traffic Inspection (Optional):**
   For approved applications, Zscaler can inspect network traffic to detect malware or enforce Data Loss Prevention (DLP) policies.

6. **Logging and Analytics:**
   All user activities are recorded in the Zscaler cloud portal, enabling reporting, threat analysis, and compliance monitoring.

• MISP (Malware Information Sharing Platform) Integration

Although Zscaler primarily controls application access, its capabilities can be strengthened by integrating with threat intelligence platforms such as MISP.

1. **Threat Intelligence Feed:**
   MISP gathers and distributes threat intelligence about malicious IP addresses, domains, and URLs. These indicators of compromise (IOCs) can be imported into the Zscaler platform.

2. **Proactive Blocking:**
   If a user attempts to access a malicious website identified in the MISP feed, Zscaler Internet Access (ZIA) can automatically block the request, preventing potential infection.

3. **Enhanced Visibility:**
   Security teams can correlate Zscaler logs with information from MISP to determine whether a destination IP or domain is linked to known threat campaigns or attackers.

• My College Network Information

The college network infrastructure has a large attack surface, particularly due to the need for remote learning and administrative access. The environment consists of:

- Core routers and switches
- Distribution routers and switches

- Wireless access points
- Firewalls and Intrusion Detection Systems (IDS)
- Internal application servers hosting systems such as the student information system, library resources, research repositories, and administrative portals
- A legacy VPN concentrator currently used by faculty and staff for remote access

The requirement for ZTNA arises because of the limitations associated with the existing VPN model:

- **Over-permitted Access:**
  Once connected to the VPN, a compromised faculty device could potentially scan or attack other systems within the internal network.
- **Restricted Collaboration:**
  Certain research applications must be accessible to external collaborators without giving them full network access.
- **Poor User Experience:**
  The traditional VPN solution can be slow and inconvenient, often forcing all internet traffic through the university network.

• How you think you deploy ZTNA using Zscaler in my college

To implement Zscaler ZTNA (ZPA) within the college environment, the initial step would involve identifying the applications that need protection and determining which user groups require access. This approach focuses on securing application access rather than the entire network.

The deployment strategy would include the following steps:

1. **Application Discovery:**
   Identify and catalog all internal applications such as ERP systems, library platforms, research servers, and shared storage currently accessed through the VPN.
2. **User Segmentation:**
   Classify users into groups like Students, Research Faculty, Administrative Faculty, IT

Staff, and External Collaborators, and determine which applications each group needs.

3. **Deploying Zscaler App Connectors:**
   Install App Connector virtual machines in the university's data center. These connectors establish outbound connections to the Zscaler cloud, ensuring the applications remain hidden from the public internet.

4. **Integrating Identity Provider:**
   Connect Zscaler with the university's existing identity platform, such as Microsoft Azure AD, to utilize existing authentication and MFA mechanisms.

5. **Configuring Access Policies:**
   Define detailed policies within the Zscaler administration portal. For instance, faculty members may be allowed to access the ERP system only from devices that have active antivirus protection and have completed MFA authentication.

6. **Deploying Zscaler Client Connector:**
   Install the Zscaler Client Connector on devices used by students, faculty, and staff. The client automatically routes traffic for private applications through ZPA while sending general internet traffic through ZIA.

• **Threat Intelligence**

Within the Zscaler and ZTNA framework, threat intelligence helps security teams understand who is accessing resources, what they are accessing, and from which locations. This enables a more context-aware security model rather than relying solely on identity verification.

Threat intelligence sources include:

1. **Zscaler Cloud Logs:**
   Provide detailed insights into application access, including user identity, device information, and geographic location.

2. **External Threat Feeds (MISP):**
   Supply intelligence about newly discovered malware campaigns, phishing domains, or command-and-control servers.

3. **Identity Provider Logs:**
   Detect suspicious authentication activity, such as login attempts from geographically distant locations within a short time period.

Threat intelligence supports several security functions:

1. **Adaptive Access Control:**
   If a user attempts to connect from a high-risk location, Zscaler can require additional authentication or deny access.
2. **Compromised Account Detection:**
   Security analysts can identify unusual access patterns that may indicate stolen credentials.
3. **Blocking Malicious Communication:**
   Threat intelligence feeds allow Zscaler Internet Access (ZIA) to prevent connections to known malicious domains even when requests originate from internal users.

• Incident Response (Adapted for ZTNA)

Incident response in a ZTNA environment becomes faster and more precise because access is tightly controlled.

1. **Detection:**
   The security operations center (SOC) identifies suspicious activity—for example, a faculty account downloading a large amount of research data late at night. Zscaler logs provide detailed information about the user, device, application, and data volume.
2. **Containment:**
   Security administrators can immediately disable the user account or block the associated device through the Zscaler portal, instantly stopping all application access.
3. **Eradication:**
   The affected device is isolated and scanned for malware by the IT support team.
4. **Recovery:**
   After the device is cleaned and the user credentials are reset, access can be restored through the updated Zscaler policies.

5. **Post-Incident Review:**
   The security team reviews logs to determine the root cause, such as a phishing attack, and updates policies accordingly to prevent similar incidents.

Benefits of this incident response model include:

- Rapid containment of threats through cloud-based controls
- Prevention of lateral movement since users never gain full network access
- Detailed forensic data for investigations
- Improved compliance with data protection regulations by demonstrating strict access controls

• Understanding about the tool (Zscaler ZPA)

Zscaler Private Access (ZPA) is a cloud-delivered solution designed to implement the Zero Trust principle of connecting users directly to applications rather than to the network.

Important aspects of ZPA include:

1. **Application-Focused Security:**
   Policies are defined around individual applications rather than IP addresses or network segments.
2. **Network Concealment:**
   Internal servers remain hidden because App Connectors initiate only outbound connections to the Zscaler cloud, eliminating the need for inbound firewall rules.
3. **Dark Cloud Model:**
   To external scanners, the organization's applications appear nonexistent. They become accessible only after proper authentication and authorization.
4. **Improved User Experience:**
   The Zscaler Client Connector operates seamlessly in the background, eliminating the need for complicated VPN connections. Some web applications can even be accessed directly through a browser.
5. **High Scalability:**
   Since ZPA operates entirely from the cloud, it can easily support thousands of users simultaneously without requiring additional hardware upgrades.

Conclusion: -

- **Stage 1 Conclusion**

Stage 1 focused on identifying common web application vulnerabilities using OWASP and CWE standards. Vulnerabilities such as path traversal, SQL injection, cryptographic failures, and hard-coded passwords were analysed to understand their causes and risks. This stage highlighted how insecure coding practices can expose applications to cyber attacks. By implementing proper validation, encryption, and secure coding methods, these risks can be reduced. Overall, this stage emphasized the importance of security during the development process.

- **Stage 2 Conclusion**

Stage 2 involved performing vulnerability assessment using the Nessus scanning tool. The scan identified several issues such as outdated TLS versions, weak encryption parameters, and missing security headers. Even informational findings helped reveal system configuration details that could be useful for attackers. The Nessus report provided severity levels and remediation suggestions for each vulnerability. This stage demonstrated how automated scanning tools help organizations detect and fix security weaknesses effectively.

- **Stage 3 Conclusion**

Stage 3 focused on implementing Zero Trust Network Access (ZTNA) using the Zscaler platform. Unlike traditional VPNs, ZTNA verifies user identity and device status before granting access to applications. Users are connected only to the specific applications they need rather than the entire network. Zscaler Private Access establishes secure encrypted connections and continuously monitors access activities. This stage showed how Zero Trust architecture improves modern network security.**Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Future Scope: -

Stage 1 – Web Application Vulnerability Analysis

Stage 1 focused on studying common web application vulnerabilities based on OWASP and CWE standards. Vulnerabilities such as path traversal, SQL injection, missing encryption, and hard-coded passwords were analysed to understand their impact on system security. These vulnerabilities occur due to poor input validation, weak security configurations, or insecure coding practices. Attackers can exploit these weaknesses to gain unauthorized access or compromise sensitive data. Understanding these vulnerabilities helps developers implement better security controls and improve application security.

Stage 2 – Vulnerability Assessment Using Nessus

Stage 2 involved performing vulnerability scanning using the Nessus tool to identify security issues in a web application. Nessus scans the target system and detects vulnerabilities related to network services, encryption protocols, and system configurations. The scan results showed issues such as deprecated TLS versions, weak cryptographic parameters, and missing security headers. Each vulnerability was categorized based on severity and included recommendations for remediation. This stage demonstrated the importance of vulnerability assessment in strengthening system security.

Stage 3 – Implementing ZTNA Using Zscaler

Stage 3 focused on implementing Zero Trust Network Access using the Zscaler security platform. ZTNA follows the principle of "never trust, always verify," ensuring that every access request is authenticated and validated. Zscaler Private Access allows users to securely connect only to authorized applications instead of the entire network. It verifies user identity, device security posture, and contextual factors before granting access. This approach reduces the attack surface and prevents unauthorized access, improving overall cybersecurity.

Topics Explored:

- Data Collection and Aggregation
- Owasp Top 10
- Scanning
- Vulnarability

- Awarness and Identity
- Standardization and Normalisation
- Enrichment and Analysis
- Integration with Security Tools
- Customization and Flexibility

Tools Explored:

- Zscaler
- Website
- Nessus
- OWASP ZAP
- ginandjuice